

Semana 1 — HTTP, sesiones y Burp

Resultado de la semana

Al terminar podrás capturar una interacción web, enumerar entradas y estados, repetirla cambiando una variable, distinguir autenticación de autorización y justificar la evidencia sin atribuir significado automático a 200, 401 o 403.

- Carga: cinco sesiones de 100-115 minutos.
- Material de trabajo: navegador, Burp Suite Community o proxy equivalente, aplicación local/CTF autorizada con login y dos cuentas, [plantilla de sesión](#).
- Regla de ayuda: aplica [el sistema de pistas](#); solucionario solo en nivel 7.

Antes de empezar crea:

- una copia de la [plantilla de sesión](#) por día;
- una fila inicial en el [registro de autonomía](#);
- dos cuentas de laboratorio, A y B, sin datos reales.

Día 1 — Anatomía de una interacción HTTP (105 min)

Recuperación activa (10 min)

Sin apuntes:

1. Escribe una petición HTTP mínima con método, path, host y cuerpo.
2. Enumera todos los lugares donde una aplicación puede recibir entrada.
3. ¿Qué demuestra realmente un 200?
4. ¿Qué diferencia hay entre transportar JSON y procesarlo?

Estudio asignado (30 min)

Lee [HTTP, formularios, cookies y sesiones](#), solo:

1. Ciclo petición-respuesta.
2. Métodos, cabeceras y estados.
3. Formatos de entrada.

No leas todavía el caso guiado.

Explicación (10 min)

Toma una petición propia y completa entrada → formato/parser → handler/sink → respuesta/evidencia. Señala qué controla el cliente y qué solo observa.

Ejercicio (20 min)

Resuelve E01 del [cuaderno](#). Añade dos entradas que no estén en el cuerpo y clasifica su parser probable. No consultes la solución.

Práctica (30 min)

En una aplicación autorizada:

1. Captura una petición GET y una POST.
2. Envíalas a Repeater.
3. Guarda baseline de estado, longitud, cabeceras y elemento semántico de respuesta.
4. Cambia solo una query, cabecera o propiedad del cuerpo.
5. Repite el baseline para descartar variación natural.

Cierre y criterio (5 min)

Finaliza si puedes marcar todas las entradas de ambas peticiones, asignar parser probable y explicar por qué una diferencia no confirma todavía vulnerabilidad. Agenda la reconstrucción D1 para el inicio del día 2.

Día 2 — Cookies, sesión y estado (110 min)

Recuperación activa (12 min)

1. Reconstruye la petición POST de ayer sin verla.
2. ¿Dónde termina HTTP y empieza el parser del cuerpo?
3. Nombra tres causas distintas de una respuesta diferente.
4. ¿Una cookie es siempre una sesión? Formula dos alternativas.

Corrige durante dos minutos con el documento, no releando toda la sección.

Estudio asignado (28 min)

Continúa HTTP y sesiones:

1. Cookies, sesiones y autenticación.
2. Modelo mental.
3. Práctica segura.

Explicación (10 min)

Describe navegador → cookie/token → resolución de estado server-side → identidad → política → recurso. Indica dónde verificarías expiración y revocación.

Ejercicio (20 min)

Resuelve E03. Debes escribir observación, qué sabes realmente, tres hipótesis, experimento discriminatorio y resultado esperado por hipótesis.

Práctica (35 min)

Con cuenta A:

1. Captura petición anónima, login, recurso autenticado y logout.
2. Repite el recurso sin cookie, con cookie original y después de logout.
3. Cambia únicamente el identificador de sesión por un valor inexistente.
4. Compara estado, cuerpo, redirect y datos, no solo código HTTP.

No pruebes tokens de terceros ni fuera del laboratorio.

Cierre y criterio (5 min)

Finaliza si puedes decir qué evidencia sugiere sesión server-side, si logout invalida el estado y qué control impide confundir caché con sesión activa.

Día 3 — Burp Repeater como instrumento experimental (105 min)

Recuperación activa (10 min)

1. Dibuja el ciclo completo de sesión de ayer.
2. ¿Qué cuatro elementos conservarías al crear un baseline?
3. ¿Qué variable cambiaste y qué controles usaste?
4. ¿Qué diferencia existe entre ausencia de autenticación y falta de autorización?

Estudio asignado (25 min)

Lee chuleta HTTP y Burp completa. Úsala como procedimiento operativo, no como teoría nueva. Después relee solo Caso guiado: ¿sesión, caché o autorización? de HTTP y sesiones.

Explicación (10 min)

Graba o escribe una explicación de dos minutos: cómo usar Repeater para cambiar una sola variable y cómo elegir evidencia semántica.

Ejercicio (25 min)

Empieza E17. Diseña las seis peticiones antes de ejecutarlas. Para cada una anota variable modificada, hipótesis y predicción.

Práctica (30 min)

Ejecuta las seis peticiones en la aplicación local con cuentas A y B. Nómbralas A-propio, B-propio, B-objeto-A, anónimo, logout y control-repetido. Conserva un detalle de respuesta que identifique al propietario sin almacenar datos sensibles.

Cierre y criterio (5 min)

Finaliza si ninguna petición cambia simultáneamente identidad y objeto, y si puedes reconstruir el historial desde tus etiquetas.

Día 4 — Autenticación frente a autorización (115 min)

Recuperación activa (12 min)

Sin Burp ni apuntes:

1. Reproduce la matriz identidad/objeto de ayer.
2. Predice anónimo → objeto A, A → objeto A, B → objeto A.
3. ¿Por qué un 403 para B no demuestra quién posee el objeto?
4. ¿Qué control separa recurso público de acceso cruzado?

Estudio asignado (30 min)

Lee Autenticación, autorización y sesiones, solo:

1. Fundamentos técnicos y Modelo mental.
2. Preguntas que debo hacerme y Prueba mínima.
3. Caso A – Básico: pertenencia de pedidos.
4. Caso D – Falso positivo: endpoint de catálogo.

Explicación (10 min)

Completa entrada → resolución de sesión → identidad → objeto → política → sink → evidencia. Explica por qué retirar el token solo prueba autenticación.

Ejercicio (23 min)

Termina E17 sin solucionario. Después compara únicamente la solución de E17. Marca cada diferencia como omisión de control, hipótesis, identidad, objeto o estado.

Práctica (35 min)

Entrega a tu aplicación una matriz 3 × 3:

Identidad	Objeto propio	Objeto ajeno	Objeto inexistente
Anónimo			

Identidad	Objeto propio	Objeto ajeno	Objeto inexistente
A			
B			

Registra código, señal semántica y conclusión limitada. Si la aplicación no ofrece objetos por usuario, simula la matriz con un servidor local o respuestas preparadas.

Cierre y criterio (5 min)

Finaliza si puedes separar autenticación, existencia y pertenencia, y si cada conclusión está respaldada por una celda de control.

Día 5 — Mini evaluación y laboratorio ciego (110 min)

Recuperación activa (15 min)

En una hoja en blanco:

1. Escribe una petición con query, cookie y JSON.
2. Dibuja ciclo de sesión y autorización.
3. Define baseline, control negativo y evidencia semántica.
4. Enumera la secuencia para investigar un 200 inesperado.

Puntúa 1 por cada elemento correcto: método/path/Host, entradas, parser, sesión, identidad, objeto, política, baseline, control y evidencia. Objetivo: 7/10.

Estudio correctivo (15 min)

Consulta solo las secciones relacionadas con respuestas falladas. No releas módulos completos.

Explicación (10 min)

Explica un caso nuevo usando entrada, transformaciones, parser, sink, primitiva y evidencia. Si no puedes nombrar una transformación, declárala desconocida y diseña cómo observarla.

Ejercicio sorpresa (20 min)

Toma E13 sin consultar la solución. Escribe una resolución completa y una explicación alternativa que produciría las mismas respuestas.

Mini laboratorio ciego (40 min)

Pide a otra persona o usa una aplicación local que te entregue una petición autenticada sin explicar su función. Si no es posible, elige una ruta que no hayas probado.

1. Enumera entradas y estado.
2. Obtén baseline repetido.
3. Formula dos hipótesis sobre identidad/objeto.
4. Diseña tres peticiones máximas.
5. Ejecuta una variable por vez.
6. Concluye confirmado, indicio o descartado.

Aplica el reloj de pistas. No necesitas “encontrar un fallo”: un descarte sólido aprueba.

Cierre semanal (10 min)

Completa registro de autonomía y, si procede, diario de bloqueos. Agenda:

- D1: reconstruir la matriz mañana, 10 minutos.

- D7: resolver una petición distinta con cookie y JSON.
- D21: caso de transferencia sin palabras “sesión” o “autorización”.
- D45: endpoint sorpresa.

Criterio de semana completada

Marca la semana como completa solo si:

- ☐ Realizaste al menos cuatro de cinco sesiones y recuperas la quinta en 72 horas.
- ☐ E01, E03, E13 y E17 tienen respuesta propia antes del solucionario.
- ☐ Capturaste y repetiste una GET y una POST autorizadas.
- ☐ Construiste la matriz identidad/objeto con baseline y control negativo.
- ☐ Obtienes al menos 7/10 en recuperación y explicas el flujo sin apuntes.
- ☐ El laboratorio ciego tiene hipótesis, predicciones y conclusión limitada.
- ☐ Registraste nivel A-G y cualquier pista usada.

Si fallan dos o más criterios, repite los días 4 y 5 con otro endpoint; no vuelvas a leer toda la semana.